

INCIDENT RESPONSE OVERVIEW

VERSION: 1.3a
DATE: 27/03/2019
AUTHOR: SYLVAIN MARTINEZ
REFERENCE: ESC15-MUSCL
CLASSIFICATION: PUBLIC



CONTENTS

CONTEXT

- Incident Response Overview;
- Incident Response Life Cycle;

RESPONSE

- Rules of Engagement;
- 1. Detection;
- 2. Categorisation;
- 3. Containment;
- 4. Investigation;
- 5. Remediation;
- 6. Reporting;
- 7. Learnings.

GOING FURTHER

- Generic Response Playbook;
- Resources.

THE GOAL OF INCIDENT RESPONSE IS TO FIRST **CONTAIN** THE THREAT, THEN **REMEDiate** IT AND **RECOVER** FROM IT.

EFFICIENT INCIDENT RESPONSE RELIES ON ITS INCIDENT MANAGEMENT FRAMEWORK:

- CATEGORIES;
- ROLES;
- RESPONSABILITIES;
- COMMUNICATION;
- COORDINATION;
- PLAYBOOKS;
- SIMULATIONS;
- ETC.

INCIDENT RESPONSE LIFE CYCLE



0. RULES OF ENGAGEMENT

- 1 DO NOT ENGAGE OR INTERACT WITH THE HACKER/THREAT GROUP
 - 2 DO NOT CONNECT TO THE THREAT'S RELATED NETWORK(S) FROM YOUR ORGANISATION
 - 3 PRESERVE EVIDENCE
 - 4 COORDINATE INTERNAL AND EXTERNAL COMMUNICATION WITH MANAGEMENT
 - 5 ALL INCIDENT DETAILS MUST BE TREATED AS CONFIDENTIAL
- DO NOT MAKE THINGS WORSE!

1. DETECTION

1

WHO/WHAT DETECTED/REPORTED THE THREAT?

2

WHAT IS THE DATE AND TIME OF THE THREAT DETECTION/REPORT?

3

HOW WAS THE THREAT DETECTED/REPORTED?

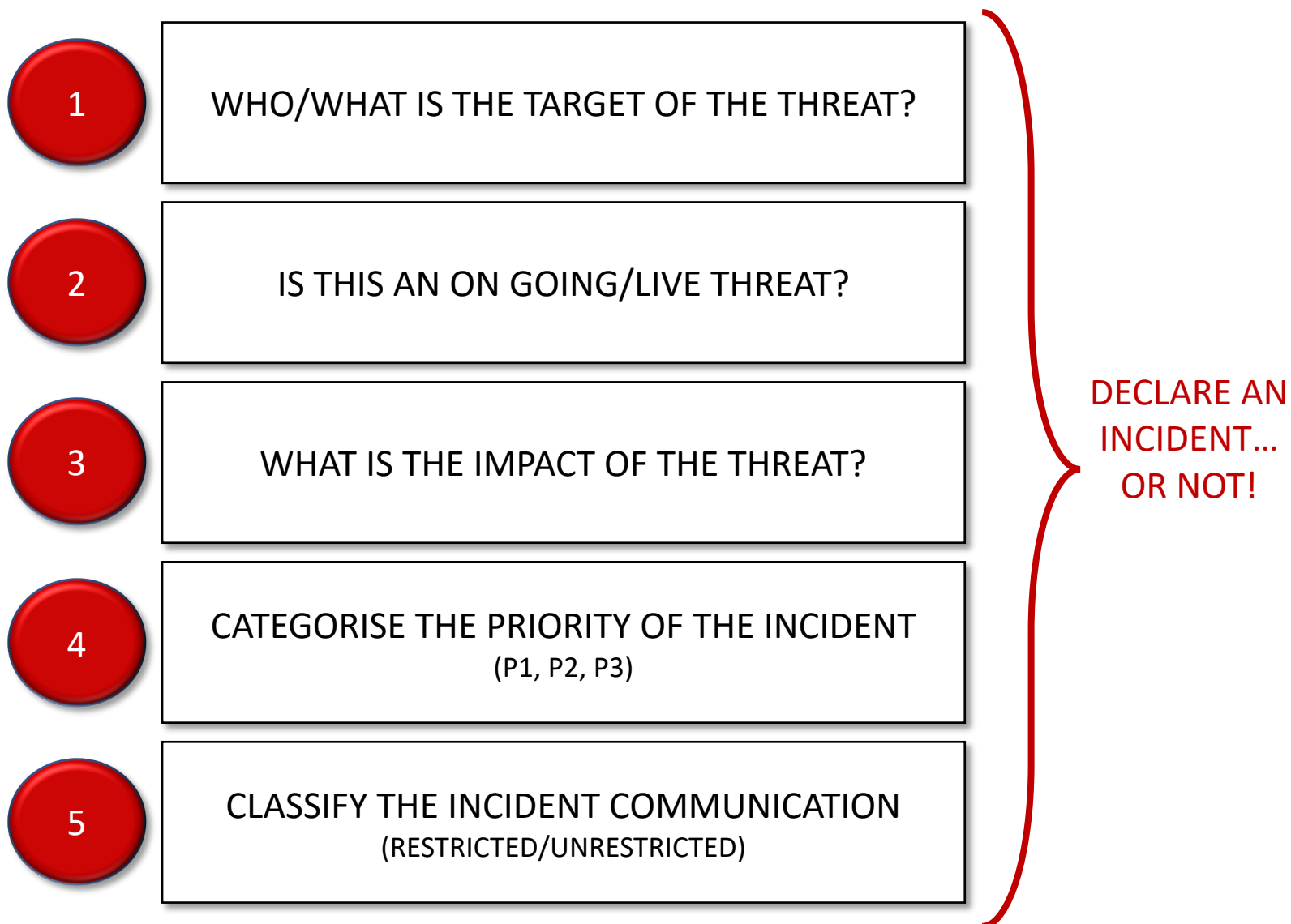
4

HAS A SIMILAR THREAT ALREADY BEEN REPORTED?

5

IS THE THREAT VALID?

2. CATEGORISATION



3. CONTAINMENT

1

COORDINATE INCIDENT MANAGEMENT
(TEAM, COMMS, ACTIVITIES, DOCUMENTATION)

2

LIGHT AND QUICK THREAT ANALYSIS
(NETWORK, HOST, USER)

3

IDENTIFY MAIN ATTACK AND COMPROMISE VECTORS
(IP, PORTS, SIGNATURES, EMAIL, ETC)

4

ISOLATE THE TARGETED ASSET
(REMOVE FROM NETWORK, DISABLE ACCOUNT, ETC)

5

IMPLEMENT EMERGENCY CHANGES AS REQUIRED
(NETWORK, HOST, USER)

4. INVESTIGATION

1

THREAT NETWORK ANALYSIS

(F/W, CLOUD APP LOGS, ASSET LOGS, INTERCEPTED TRAFFIC, TRAFFIC AND DATA FLOWS, SIEM)

2

THREAT MALWARE ANALYSIS

(A/V VENDORS, FOOTPRINT, BEHAVIOR, REVERSE ENGINEERING)

3

THREAT HOST ANALYSIS

(EVENT LOGS, APP/PLUGINS INSTALLED, AD/EMAIL ACTIVITIES, AUTHENTICATED VA TO BE DONE, SIEM)

4

THREAT USER ANALYSIS

(INTERVIEW TARGETED USER, CONTEXT, TRIGGERS, RECENT UNUSUAL ACTIVITIES/ALERTS)

5

THREAT RESEARCH ANALYSIS

(ONLINE SEARCH FOR SIMILAR THREATS, PROFESSIONAL FORUMS, VENDOR ENGAGEMENT)

5. REMEDIATION

1

THREAT NETWORK REMEDIATION

(BLOCK IP, PORTS, DOMAINS, EMAILS.
UPDATE F/W, IDS, APT AND SIEM RULES)

2

THREAT MALWARE REMEDIATION

(UPDATE HOST AND NETWORK A/V SIGNATURES.
ENGAGE WITH VENDORS THAT DID NOT DETECT THE THREAT)

3

THREAT HOST REMEDIATION

(REMOVE/BAN INFECTED APPS/PLUGINS, CLEAR INBOX RULES,
REMEDiate ISSUES FOUND DURING THE VA)

4

THREAT USER REMEDIATION

(INDIVIDUAL AND GROUP USER AWARENESS SESSION
RELEVANT TO THE THREAT)

5

DECLARE THE INCIDENT REMEDIATED

6. REPORTING

1

ON GOING REPORTING

(DOCUMENTATION AND EVIDENCE SHOULD BE GENERATED AS MUCH AS POSSIBLE DURING THE PREVIOUS PHASES)

2

EVIDENCE GATHERING

(THREAT ACTORS, ATTACK VECTORS, ATTACK SURFACE)

3

INCIDENT DOCUMENTATION

(THREAT AND INCIDENT DETAILS, TRIGGERS, OWNER, FINDINGS, TIMELINE)

4

INCIDENT REGISTER

(CREATE/UPDATE AN OVERALL INCIDENT REGISTER TO TRACK PROGRESS AND GENERATES STATISTICS. CAN BE LINKED TO OTHER REGISTERS: RISKS/ISSUES)

5

INCIDENT REPORT COMMUNICATION

(AS REQUIRED: INTERNAL/EXTERNAL, STAFF/MANAGEMENT/BOARD, VENDORS/CLIENTS, GOVERNMENT/REGULATORS)

7. LEARNINGS

1

ROOT CAUSE ANALYSIS
(IDENTIFY AND DOCUMENT INCIDENT TRIGGERS AND SECURITY GAPS THAT ENABLED THE INCIDENT TO OCCUR)

2

CONTROLS AND PROCESSES READINESS
(EVALUATE THE EFFICIENCY OF CURRENT SECURITY CONTROLS AND PROCESSES IN LIGHT OF THE INCIDENT)

3

INCIDENT TRENDS ANALYSIS
(ARE YOU LEARNING FROM PAST INCIDENTS? IS YOUR RISK PROFILE CHANGING?)

4

MITIGATION PLAN
(MITIGATE IMPACT OF SIMILAR FUTURE INCIDENTS)

5

IMPROVEMENTS PLAN
(STOP OCCURRENCE OF SIMILAR FUTURE INCIDENTS)

ANALYSIS

NETWORK

MALWARE

HOST

CONTAINMENT/REMEDIATION

- BLOCK IP/PORTS/SERVICES;
- BLOCK EMAIL;
- CHANGE PWD

- UPDATE A/V AND F/W RULES;
- REMOVE MALWARE/SERVICES;
- CHANGE PWD.

- REMOVE SOFTWARE/PLUGIN;
- UPDATE SECURITY CONFIGURATION;
REMOVE SERVICES/LOCAL ADMIN.

Forum of Incident Response and Security Teams (FIRST) FRAMEWORK

(https://www.first.org/education/FIRST_SIRT_Services_Framework_Version1.0.pdf)

National Institute of Standards and Technology (NIST) Special Procedure (SP) 800-61

(<https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-61r2.pdf>)

International Organization for Standardization (ISO) ISO/IEC 27035-1:2016

(<https://www.iso.org/standard/60803.html>)

International Organization for Standardization (ISO) ISO/IEC 27035-2:2016

(<https://www.iso.org/standard/62071.html?browse=tc>)

CONTACT US!

(contact@elysiumsecurity.com)

ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY PROVIDES A PORTFOLIO OF **STRATEGIC** AND **TACTICAL SERVICES** TO HELP COMPANIES **PROTECT** AND **RESPOND** AGAINST **CYBER SECURITY THREATS**. WE DIFFERENTIATE OURSELVES BY OFFERING **DISCREET, TAILORED** AND **SPECIALIZED** ENGAGEMENTS.

ELYSIUMSECURITY OPERATES IN **MAURITIUS** AND IN **EUROPE**, A **BOUTIQUE STYLE** APPROACH MEANS WE CAN **EASILY ADAPT** TO YOUR BUSINESS OPERATIONAL MODEL AND REQUIREMENTS TO PROVIDE A **PERSONALIZED SERVICE** THAT FITS YOUR WORKING ENVIRONMENT.

ELYSIUMSECURITY PROVIDES **HIGH LEVEL EXPERTISE** GATHERED THROUGH YEARS OF **BEST PRACTICES EXPERIENCE** IN LARGE INTERNATIONAL COMPANIES ALLOWING US TO PROVIDE ADVICE BEST SUITED TO YOUR **BUSINESS OPERATIONAL MODEL** AND **PRIORITIES**.

ELYSIUMSECURITY PROVIDES **PRACTICAL EXPERTISE** TO **IDENTIFY VULNERABILITIES**, ASSESS THEIR **RISKS** AND **IMPACT**, **REMEDiate** THOSE RISKS, **PREPARE** AND **RESPOND** TO INCIDENTS AS WELL AS RAISE **SECURITY AWARENESS** THROUGH AN ORGANIZATION.

